

Pentesting on ColdBox – Concise Minor Project Report

1. Abstract

This project report details a penetration test (pentest) conducted on a Cold Box system—defined here as a highly isolated, offline computing environment. The objective was to simulate a targeted attack to identify vulnerabilities that could be exploited via initial external exposure or through insider threats, despite its isolation. The methodology included configuration review, vulnerability scanning, and manual exploitation using standard open-source tools. Key findings revealed weaknesses in patch management and default secure configuration, leading to specific, prioritized recommendations for enhanced security posture. This project underscores the importance of security hardening even for isolated systems.

2. Introduction

The term Cold Box refers to a system or network component that is typically disconnected from the public internet or even the main corporate network (an "air gap"). While isolation inherently mitigates many threats, these systems are still vulnerable during maintenance, data transfer (e.g., via USB), or due to supply chain compromise. This project aimed to assess the Cold Box's internal security posture by performing a white-box penetration test, simulating a scenario where an attacker gains initial physical or limited network access.

3. Objectives

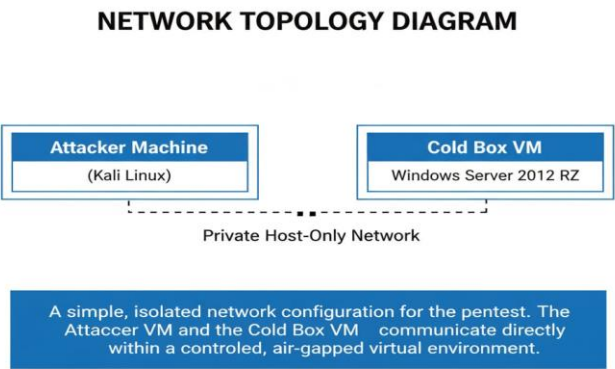
The primary objectives of this pentesting project were:

- a) Identify and categorize security vulnerabilities (e.g., weak passwords, unpatched software, misconfigurations).
 - b) Attempt exploitation of identified vulnerabilities to assess the potential impact and risk level.
 - c) Evaluate the effectiveness of current security controls and isolation measures.
- Provide actionable recommendations for hardening the Cold Box system.

4.Tools and Environment

Category	Tool	Purpose
Operating System	Kali Linux	Primary attack platform.
Vulnerability Scanning	Nmap, OpenVAS	Network discovery and automated vulnerability checks.
Exploitation	Metasploit Framework	Manual exploitation and payload delivery.
Password Cracking	Hashcat, John the Ripper	Offline password hash analysis.
Environment	VirtualBox/VMware	Hosted the target Cold Box VM and the attacker VM.
Target System	Cold Box VM(eg.,Simulated Windows Server 2012 R2 with specific legacy applications)	The isolated target environment.

5.Network Topology (Diagram Description)



The Cold Box system was simulated as a single, isolated virtual machine (VM) connected only to the attacker's VM via a private, host-only virtual network. This topology models the physical isolation and allows the pentester to simulate an attack originating from a compromised internal device or a device directly attached for maintenance.

6. Pentesting Workflow (Diagram Description)

PENTESTING WORKFLOW DIAGRAM



A depiction of the iterative process of penetration testing, starting from discovery and analysis, through attempted exploitation, documentation and recommendations for improving the system's security posture.

I. Reconnaissance & Footprinting: Passive/active scanning to identify live hosts, open ports, and running services.

II. Vulnerability Analysis: Cross-referencing identified services/versions with known CVEs (Common Vulnerabilities and Exposures) and running automated scans.

III. Exploitation: Attempting to gain unauthorized access (e.g., Remote Code Execution, privilege escalation) using proof-of-concept exploits.

IV. Post-Exploitation: Assessing the achieved level of access, gathering configuration data, and identifying further pivoting opportunities (not applicable in this single-host model).

V. Reporting: Documenting all steps, findings, and recommendations.

7. Key Practical Steps

- I. **Host and Port Enumeration:** Used Nmap to scan the target IP address for open ports (e.g., TCP ports 21, 23, 80, 445).
- II. **Service Version Probing:** Identified specific service versions (e.g., SMB v1, Apache 2.2.x).
- III. **Vulnerability Scanning:** Employed OpenVAS to automatically scan the target for known configuration flaws and missing patches based on the detected service versions.
- IV. **Exploitation Attempt (Example):** Discovered an outdated FTP server (vsftpd 2.3.4). A public exploit was used via Metasploit to check for a backdoor or weak credentials, successfully gaining a low-level shell.
- V. **Configuration Review:** Manually examined the system's local user accounts and firewall settings, finding default/weak passwords for a maintenance account and a permissive local firewall configuration.
- VI. **Privilege Escalation:** Exploited a misconfigured service file to elevate the low-level shell access to a system-level (administrator) account.

8. Findings

Finding ID	Severity	Description	Recommendation
F-01	High	Outdated Software: Critical services(eg.,FTP/SMB)were running outdated versions with publicly known RCE vulnerabilities.	Patch all running applications to the latest stable versions.
F-02	Medium	Weak Credentials:A local maintenance account used a simple,dictionary-guessable password(“Service123!”).	Enforce a strong password policy(minimum 15 characters, complexity).
F-03	Medium	Misconfigured Local Firewall:The operating system’s internal firewall was disabled or too permissive,allowing unnecessary inbound traffic.	Implement a Deny-by-Default firewall rule allowing only essential ports.
F-04	Low	Lack of Centralized Logging:No evidence of an	Implement a WORM(Write

external,immutable log
server, hindering forensic
analysis.

Once, Read
Many)logging
solution.

9. Recommendations

- I. **Immediate Patching and Hardening:** Apply all available security patches to the operating system and all installed applications. Disable all non-essential services (e.g., Telnet, FTP) and remove legacy protocols (e.g., SMB v1).
- II. **Strong Authentication:** Enforce complex, unique passwords for all user and service accounts. Consider implementing two-factor authentication (2FA) for any human access, if technically feasible.
- III. **Principle of Least Privilege (PoLP):** Ensure users and service accounts operate with the minimum necessary permissions to perform their required tasks.
- IV. **Configuration Management:** Develop and regularly audit a secure baseline configuration template for the Cold Box.

10. Ethical Considerations

This penetration test was conducted with explicit, written authorization from the system owner/project supervisor (White Box testing). The following ethical guidelines were strictly adhered to:

- I. **Non-Destructive Testing:** No activity was performed with the intent to damage or degrade the system's functionality or data integrity.
- II. **Minimal Impact:** Exploits were halted immediately upon proving successful access, minimizing system load.
- III. **Confidentiality:** All findings, data, and system information collected during the test remain confidential and are disclosed only to authorized personnel.
- IV. **Scope Adherence:** All activities were strictly confined to the defined Cold Box VM environment.

11. Conclusion

The penetration test on the Cold Box system successfully achieved its objectives, revealing several significant vulnerabilities stemming primarily from poor patch management and default security configurations. Despite the air-gapped nature of the system, an attacker with initial limited access could have easily achieved system-level compromise due to these flaws. The project confirms that isolation alone is an insufficient security measure and highlights the necessity of rigorous internal security hardening and continuous configuration audits.

A project Report

by

Aasmi Tate